the machinery that map those choices into reality:

- Which signals should be pulled in for this request?
- How are they delivered—embedded in a token, fetched from an API, streamed via an event bus?
- How fresh do they need to be, and how long can they be cached?

At ACME, this diversity is clearly visible. The Customer Collaboration platform connects with the customer information system to verify account status, while also consuming OAuth tokens from the identity provider that contain customer ID and role. When employees use the same platform, the PIP layer retrieves additional data from HR (employment status) and Finance (authorization limits) and validates a device-posture token that accompanies the access request, issued by the posture client on the device. In the engineering deployment tool, the PIP must also contact PagerDuty to check if the requesting engineer is on call.

From the perspective of the PDP, all of this comes together as a coherent set of attributes and relationships used in policy evaluation. But under the hood, the PIP is less a single component than an ecosystem of integrations. Each contributes pieces of the context puzzle, and the quality of authorization depends on how well those pieces are assembled, secured, and kept fresh.

12.2 Entities: principals and resources

Policy Information Points collect raw data, but policies need that data in a structured form. To evaluate a request, a Policy Decision Point (PDP) must be able to reason about who is acting (the principal), what they want to access (the resource), and what attributes or relationships tie them together. These structured representations—*entities*—are the foundation of authorization context.

An entity is more than a record; it’s a model of a principal or resource meaningful to policy. A principal might be an employee, customer, or service account. A resource could be a document, project, or financial record. Each entity carries attributes such as role, department, owner, or classification,